

Security Incident Report

Report ID	CLD-IR-0001
Related ticket	CLD-001 – Suspicious sign-in activity: Daniel.reeve@cloudora.io
Report title	Executive account takeover via password spray, with MFA persistence and BEC staging
Analyst	Eshak Basta
Date of report (UTC)	8/7/2026
Incident severity	P2: The incident was classified as P2 because two user accounts were compromised through a password-spray attack, unauthorized MFA registration and mailbox manipulation were observed, and the attacker accessed multiple Microsoft 365 services. However, the incident was contained on the same day, and no confirmed data loss was identified
Status	Contained: Active sessions and tokens were revoked, MFA was reset, and the malicious IP address was blocked. The account will continue to be monitored for suspicious activity.
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

An unauthorized attacker successfully compromised CEO Daniel Reeve’s account following repeated password-spray attempts. After gaining access, the attacker registered their own phone as a trusted MFA device, accessed Outlook and Azure, and created a malicious mailbox rule to hide financial emails from the CEO. The attacker also compromised Priya Nair’s account and used it to access SharePoint Online.

The incident was contained by revoking active sessions and tokens, resetting MFA, removing the unauthorized MFA device and malicious mailbox rule, and blocking the identified attacker IP addresses. The accounts affected will continue to be monitored for further suspicious activity.

2. Incident timeline

Time (UTC)	Source	Event	Evidence / notes
Aug 8, 00:07-04:58	Sign-in logs	Password spray begins	Multiple accounts targeted from 102.89.44.17, 102.89.44.23, and 102.89.45.101 in Lagos, Nigeria . ResultType 50126 (invalid username/password), Windows 10 / Chrome 125. 44 failed sign-in attempts total
Aug 8, 02:22:31	Sign-in logs	CEO targeted	Failed authentication for Daniel Reeve from 102.89.45.101, Lagos. ResultType 50126 .
Aug 8, 03:16:43	Sign-in logs	Priya targeted	Failed authentication for Priya Nair from 102.89.44.17, Lagos. ResultType 50126 .

Aug 9, 00:14–04:50	Sign-in logs	Password spray continues	Multiple accounts targeted from the same 102.89.x.x infrastructure. ResultType 50126.
Aug 9-10, 01:57:27 – 03:09:12	Sign-in logs	CEO targeted again	3 Failed Daniel authentication from 102.89.45.101, Lagos. ResultType 50126
Aug 10, 03:12:05	Sign-in Logs	CEO account compromised	Successful Microsoft 365 authentication as Daniel from 102.89.44.17, Lagos, Windows 10 / Chrome 125. ResultType 0 (Success).
Aug 10, 03:14:30	Sign-in Logs	CEO mailbox accessed	Successful Outlook Web access from 102.89.44.17. ResultType 0 (Success)
Aug 10, 03:18:44	Audit logs	Unauthorized MFA registered	Attacker registered an Authenticator app on a Pixel 6 to Daniel's account from 102.89.44.17. Audit result: Success.
Aug 10, 03:26:02	Sign-in logs	Azure portal accessed	Successful Azure Portal access from 102.89.44.17, Lagos. ResultType 0 (Success).
Aug 10, 03:31:09	Audit logs	Malicious inbox rule created	"RSS Subscriptions" rule moved emails from finance@cloudora.io or containing "invoice" to RSS Feeds and marked them as read. Audit result: Success
Aug 10, 03:44:55	Sign-in logs	Priya login attempt	Failed authentication from 102.89.45.101, Lagos. ResultType 50126.
Aug 10, 03:47:18	Sign-in Logs	Priya account compromised	Successful Microsoft 365 authentication from 102.89.45.101, Lagos, Windows 10 / Chrome 125. ResultType 0 (Success).
Aug 10, 03:52:40	Sign-in Logs	SharePoint accessed	Successful SharePoint Online access using Priya's account from 102.89.45.101. ResultType 0 (Success).
Aug 10, 07:31:11	Sign-in Logs	Legitimate Priya activity	Successful login from 203.0.113.10 , London, iOS 17 / Mobile Safari. ResultType 0. Helps distinguish legitimate activity from the Lagos session.
Aug 10, 08:41:00	Sign-in Logs	Legitimate CEO activity	Successful login from 203.0.113.11 , London, macOS 14 / Safari 17. ResultType 0. Contrasts with the attacker's Lagos Windows/Chrome session

3. Findings

Finding 1: Password Spray Activity

Multiple Cloudora accounts were targeted by repeated failed authentication attempts from Lagos-based IP addresses.

Evidence: Sign-in logs showed repeated **ResultType 50126 (invalid username/password)** events from 102.89.44.17, 102.89.44.23, and 102.89.45.101 between August 8–10 across multiple accounts.

Why it matters: The pattern is consistent with password spraying and occurred before the successful account compromises.

Finding 2: CEO Account Compromise

CEO Daniel Reeve's account was successfully accessed from suspicious infrastructure in Lagos, Nigeria.

Evidence: Sign-in logs showed failed attempts at **03:09:12** and **03:10:41 UTC**, followed by a successful authentication (**ResultType 0**) at **03:12:05 UTC** from 102.89.44.17 using Windows 10 / Chrome 125.

Why it matters: This confirms unauthorized access to the CEO's account.

Finding 3: CEO Mailbox Access

The attacker successfully accessed Daniel Reeve's mailbox after compromising his account.

Evidence: Sign-in logs showed successful **Outlook Web** access (**ResultType 0**) at **03:14:30 UTC** from attacker IP 102.89.44.17.

Why it matters: This confirms the attacker gained access to the CEO's email environment.

Finding 4: Unauthorized MFA Device Added

An unauthorized MFA device was registered to Daniel Reeve's account after the compromise.

Evidence: Audit logs showed a **User registered security info** event at **03:18:44 UTC** from 102.89.44.17, registering an Authenticator app on a **Pixel 6**.

Why it matters: The additional MFA method provided the attacker with a way to maintain access to the compromised account.

Finding 5: Azure Portal Access

Daniel Reeve's compromised account was used to access the Azure Portal.

Evidence: Sign-in logs showed successful Azure Portal access (ResultType 0) at 03:26:02 UTC from attacker IP 102.89.44.17 in Lagos.

Why it matters: This confirms the attacker's activity extended beyond the CEO's mailbox into additional cloud resources.

Finding 6: Malicious Inbox Rule Created

A malicious inbox rule was created to hide financial emails from Daniel Reeve.

Evidence: Audit logs showed the "RSS Subscriptions" rule was created at **03:31:09 UTC**. Emails from **finance@cloudora.io** or containing "invoice" were moved to RSS Feeds and marked as read.

Why it matters: The rule concealed financial communications from the CEO and could support financial fraud or business email compromise activity.

Finding 7: Priya Nair Account Compromise

Priya Nair's account was also successfully accessed from suspicious infrastructure in Lagos.

Evidence: Sign-in logs showed a failed authentication (ResultType 50126) at **03:44:55 UTC**, followed by a successful authentication (ResultType 0) at **03:47:18 UTC** from 102.89.45.101 using Windows 10 / Chrome 125.

Why it matters: This confirms the attacker compromised a second Cloudora account and expanded the scope of the incident.

Finding 8: SharePoint Access Through Priya

Priya Nair's compromised account was used to access SharePoint Online.

Evidence: Sign-in logs showed successful SharePoint Online access (ResultType 0) at **03:52:40 UTC** from attacker IP **102.89.45.101**.

Why it matters: This confirms the compromised account was used to access additional organizational resources and created potential exposure of SharePoint data.

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
IP Address	102.89.44.17	Aug 8	Password spraying; later used to compromise Daniel, access Outlook/Azure, add MFA, and create mailbox rule
IP Address	102.89.44.23	Aug 8	Password-spray attempts against Cloudora accounts
IP Address	102.89.45.101	Aug 8	Password spraying; later used to compromise Priya and access SharePoint
Location	Lagos, Nigeria	Aug 8	Location associated with attacker sign-in activity
Device / User Agent	Windows 10 / Chrome 125	Aug 8	Device profile consistently associated with suspicious sign-ins
MFA Device	Pixel 6 / Authenticator	Aug 8	Unauthorized MFA device registered to Daniel's account
Mailbox Rule	RSS Subscriptions	Aug 8	Malicious rule used to hide finance/invoice emails by moving them to RSS Feeds and marking them read

5. MITRE ATT&CK; mapping

Tactic	Technique ID	Technique name	Evidenced by
Credential Access	T1110.003	Password Spraying	Repeated 50126 failures against multiple accounts from 102.89.x.x IPs
Initial Access	T1078	Valid Accounts	Successful unauthorized logins to Daniel and Priya using valid accounts
Persistence	T1098.005	Device Registration	Unauthorized Pixel 6 registered as an MFA device on Daniel's account
Collection	T1213.002	SharePoint	Priya's compromised account was used to access SharePoint Online
Defense Evasion	T1070.008	Clear Mailbox Data	Malicious RSS Subscriptions rule moved financial/invoice emails and marked them as read to hide them from the CEO
Collection	T1114.002	Remote Email Collection	Successful Outlook Web App access from attacker IP after account compromise, showing remote access to the victim mailbox
Collection	T1213.002	SharePoint Collection	Successful SharePoint Online access from attacker IP 102.89.45.101 during

the compromised Priya Nair session, confirming access to additional cloud-hosted organizational resources.

6. Scope

Accounts confirmed compromised

- Daniel Reeve (CEO) – Account and mailbox compromised
- Priya Nair – Account compromised and used to access SharePoint

Accounts targeted but not breached

- 24 additional Cloudora accounts were targeted during the password-spray attack.
- All attempts against these accounts failed (**ResultType 50126**); no successful attacker logins were identified

Accounts investigated and cleared (false positives)

- The 24 targeted accounts were reviewed for successful authentication from the attacker infrastructure.
- No evidence of compromise was identified for these accounts.

Affected Services

- Microsoft 365
- Outlook Web
- Azure Portal
- SharePoint Online
- MFA / Authentication services

7. Actions taken

Time (UTC)	Action	Performed by	Verified how
04:05	Revoked all active sessions for Daniel and Priya	SOC Analyst	Checked Entra ID sign-in logs and confirmed no continued activity from the existing attacker sessions
04:08	Revoked/reset authentication tokens	SOC Analyst	Checked Entra ID and confirmed subsequent access required reauthentication
04:12	Removed unauthorized Pixel 6 MFA device	SOC Analyst	Checked Daniel's authentication methods in Entra ID and confirmed the unauthorized device was no longer registered

04:16	Reset credentials and MFA	SOC Analyst	Verified the password resets in Entra ID and confirmed both users could authenticate with legitimate MFA
04:20	Removed malicious "RSS Subscriptions" mailbox rule	SOC Analyst	Checked Daniel's mailbox rules in Exchange and confirmed the malicious rule was removed
04:25	Blocked 102.89.44.17, 102.89.44.23, and 102.89.45.101	SOC Analyst	Checked the IP blocking policy and confirmed 102.89.44.17, 102.89.44.23, and 102.89.45.101 were blocked
04:40	Investigated remaining targeted accounts	SOC Analyst	Queried Entra ID sign-in logs for the attacker IPs and found no successful attacker logins on the remaining accounts
05:00	Began post-containment monitoring	SOC Analyst	Reviewed Entra ID sign-in and audit logs and found no new activity from the attacker infrastructure

8. Recommendations

Quick Wins

- Enable password-spray detection and automatic blocking. (*Finding 1*)
- Require phishing-resistant MFA for sensitive accounts. (*Findings 2, 4, 7*)
- Restrict and alert on new MFA device registrations. (*Finding 4*)
- Alert on suspicious mailbox rule creation. (*Finding 6*)

Strategic Changes

- Use Conditional Access to block high-risk locations, IPs, and devices. (*Findings 2, 7*)
- Alert on impossible travel and unusual account activity. (*Findings 2, 5, 7, 8*)
- Apply least-privilege access to SharePoint and sensitive cloud resources. (*Findings 5, 8*)

9. Outstanding Actions

1. Complete the SharePoint investigation

Review SharePoint audit logs associated with Priya Nair's compromised session to determine which sites, folders, libraries, and files were accessed from the attacker IP address (102.89.45.101). Determine whether any content was viewed, downloaded, modified, shared, or deleted.

2. Expand the mailbox investigation

Perform a comprehensive review of both compromised mailboxes to identify any additional unauthorized changes. Review inbox rules, forwarding rules, delegated access, mailbox permissions, and other mailbox configuration changes that could have been used to hide, redirect, or exfiltrate email data.

3. Assess potential data exposure

Determine whether any data accessed through Outlook Web, Azure Portal, or SharePoint contained sensitive organizational information. If sensitive information was accessed, perform a formal data-exposure assessment to determine whether additional reporting or notification procedures are required.

4. Continue post-containment monitoring

Continue monitoring Daniel Reeve's and Priya Nair's accounts for unusual authentication activity, unauthorized MFA registrations, mailbox modifications, or additional cloud resource access. Review sign-in and audit logs to confirm that no further activity is observed from the identified attacker infrastructure.

5. Validate the scope of the incident

Review the remaining accounts targeted during the password-spray campaign to confirm that no additional compromised accounts were missed during the investigation. Revalidate sign-in activity associated with the identified attacker IP addresses and document any newly discovered activity.

10. Lessons learned

What worked: Sign-in and audit logs helped identify the compromised accounts, attacker IPs, MFA changes, and post-compromise activity, including mailbox and SharePoint access.

What was slow/missing: Although the phishing campaign was reported at 09:11 UTC, Ryan Boyd had already submitted his credentials at 09:05 UTC and was not identified as a second compromised user until later in the investigation. This created a response gap during an active campaign.

What should improve: When a phishing campaign is confirmed, all users who clicked the phishing link and submitted credentials should be immediately identified, prioritized, and remediated through password resets and session revocation before additional attacker activity occurs.

